PlaceSecrets

Příručka administrátora

Instalace, správa, architektura a zabezpečení

POI AudioGuide & Travel Log
Mobilní aplikace • Webový portál • Supabase backend

Verze dokumentu k 14. 6. 2026

Obsah

1 Úvod **2**

2 Architektura systému **2**
2.1 Přehled . . . 2
2.2 Struktura repozitáře . . . 2
2.3 Klíčové datové struktury (PostgreSQL) . . . 2
2.4 Edge funkce (15) . . . 2

3 Instalace a první nasazení **3**
3.1 Předpoklady (účty a nástroje) . . . 3
3.2 Backend (Supabase) . . . 3
3.3 Webový portál . . . 4
3.4 Mobilní aplikace . . . 4

4 Webové administrační rozhraní **4**

5 Zabezpečení **5**
5.1 Autentizace a autorizace . . . 5
5.2 admin-api proxy – žádný service_role ve frontendu . . . 5
5.3 Row Level Security (RLS) . . . 5
5.4 Storage (úložiště) . . . 5
5.5 Platby a webhooky . . . 5
5.6 Hodnocení míst . . . 6
5.7 GDPR . . . 6
5.8 Web – bezpečnostní hlavičky . . . 6
5.9 Správa tajných klíčů . . . 6

6 Údržba a provoz **6**
6.1 CI/CD . . . 6
6.2 Monitoring . . . 6
6.3 Migrace databáze . . . 7
6.4 Zálohy a obnova . . . 7
6.5 Časté administrátorské úkoly . . . 7

7 Řešení problémů **7**

8 Odkazy **7**

1 Úvod

Tento dokument je úplná příručka pro **administrátora a provozovatele** systému PlaceSecrets. Po jeho přečtení má být jasné, *co kde je*, *jak to nainstalovat a nasadit*, *jak to spravovat* a *jak je vyřešené zabezpečení*.

Systém se skládá ze tří částí sdílejících jeden backend:

- **Mobilní aplikace** (Flutter, Android + iOS) – pro koncové uživatele.
- **Webový portál** (React) – veřejná část *a* administrace.
- **Backend** (Supabase: PostgreSQL, Auth, Storage, Edge Functions).

Doprovodné dokumenty v repozitáři. Tato příručka shrnuje a odkazuje na: `app/BUILD.md` (build mobilu), `backend/DEPLOYMENT.md` (nasazení backendu), `backend/PRODUCTION_SETUP.md` (produkční data), `RELEASE-CHECKLIST.md` (co musí udělat člověk vs. co je hotové v kódu) a `APP-GAP-ANALYSIS.md` (stav a analýza).

2 Architektura systému

2.1 Přehled

Vrstva	Technologie
Mobil	Flutter/Dart, Riverpod, GoRouter, Drift (SQLite), supabase_flutter flutter_map (OSM), just_audio + flutter_tts, geofencing, Firebase FCM
Web	Vite + React 18 + TypeScript + Tailwind CSS, react-i18next (11 jazyků)
Backend	Supabase: PostgreSQL + RLS, Auth, Storage, Edge Functions (Deno)
Platby	Stripe (mobil checkout/refund), Comgate (web), Google/Apple Pay, Revolut

2.2 Struktura repozitáře

```
place-secrets/
  app/          ... Flutter mobilni aplikace (balicek cz.tuma.placesecrets)
  web/          ... React webovy portal (verejna cast + /admin administrace)
  backend/      ... Supabase: migrace, edge funkce, seed
    supabase/migrations/   ... 64 SQL migraci (forward-only)
    supabase/functions/    ... 15 edge funkci (Deno/TypeScript)
  tex/          ... tento dokument
  .github/workflows/ci.yml ... CI (web, edge, mobile, e2e)
  APP-GAP-ANALYSIS.md, RELEASE-CHECKLIST.md ... stav a checklist
```

2.3 Klíčové datové struktury (PostgreSQL)

Hlavní tabulky: `cities`, `pois`, `countries`, `poi_types`, `poi_audio_guides`, `poi_ratings` (hodnocení), `user_profiles`, `admin_users` (administrátoři + PIN), `contributor_profiles`, `acl_permissions` (role × zdroj × R/W/D), `payment_config`, `payment_receipts` (účtenky), `landing_config` (CMS úvodní stránky) a tabulky nároků: `user_access`, `user_poi_purchases`, `user_city_premium_purchases`, `user_country_purchases`, `free_visit_log`. Na všech je zapnuté **Row Level Security (RLS)**.

2.4 Edge funkce (15)

`admin-api` (proxy všech admin operací), `verify-admin-pin`, `change-admin-pin`, `invite-contributor`, `confirm-payment`, `generate-receipt`, `create-payment-intent`,

`create-poi-checkout`, `confirm-poi-payment`, `payment-webhook`, `stripe-refund`, `comgate-create`, `comgate-webhook`, `delete-user-data` (GDPR), `migrate-anonymous-data`.

3 Instalace a první nasazení

Nasazení má čtyři kroky: **backend**, **web**, **mobil** a **doménové/účtové** úkony. Pořadí: nejdřív backend (na něm závisí web i mobil).

3.1 Předpoklady (účty a nástroje)

- Supabase projekt (produkční, případně i staging).
- Firebase projekt (push notifikace – FCM).
- Apple Developer + Google Play Console (vydání aplikací).
- Platební brány: Stripe a/nebo Comgate (živé klíče).
- Hosting webu: Netlify nebo Vercel; doména `placesecrets.app`.
- Nástroje: `supabase` CLI, `flutter` SDK, `node` 22, `git`.

3.2 Backend (Supabase)

Podrobně v `backend/DEPLOYMENT.md`. Stručně (spouštět v `backend/`):

```
npx supabase login
npx supabase link --project-ref <PROJECT_REF>
npx supabase db push          # aplikuje vsech 64 migraci

# tajne klice (viz tabulka v sekci Zabezpeceni):
npx supabase secrets set STRIPE_SECRET_KEY=... \
  COMGATE_MERCHANT=... COMGATE_SECRET=... \
  WEBHOOK_SECRET=$(openssl rand -hex 32) \
  RESEND_API_KEY=... APP_URL=https://placesecrets.app

# nasazeni vsech 15 edge funkci:
for fn in admin-api verify-admin-pin change-admin-pin \
    invite-contributor confirm-payment generate-receipt \
    create-payment-intent create-poi-checkout confirm-poi-payment \
    payment-webhook stripe-refund comgate-create comgate-webhook \
    delete-user-data migrate-anonymous-data; do
  npx supabase functions deploy "$fn"
done
```

Konfigurace Auth (dashboard). V *Authentication*:

- **Redirect URLs**: přidat `placesecrets://login-callback` (OAuth z mobilu) a originy webu.
- **Providers**: zapnout Google a Apple (client id/secret).
- E-mailové šablony (potvrzení registrace, reset hesla).

Produkční data. Podle `backend/PRODUCTION_SETUP.md`: nasypat `countries`, nastavit `payment_config` (ceny, `free_count`), vytvořit prvního `superadmin`a, založit města a místa (přes administraci). Testovací seed (`seed.sql`) do produkce **nepatří**.

3.3 Webový portál

Deploy konfigurace je v repozitáři hotová (`web/netlify.toml`, `web/vercel.json`, `web/public/_redirects`). Na hostingu nastavte proměnné prostředí (injektují se při buildu):

```
VITE_SUPABASE_URL=https://<ref>.supabase.co
VITE_SUPABASE_ANON_KEY=<publikovatelny anon klic>   # chranen pomoci RLS
VITE_SENTRY_DSN=<volitelne, pro error tracking>
```

Build: `npm ci && npm run build` (výstup `dist/`). SPA fallback i bezpečnostní hlavičky (CSP, X-Frame-Options, …) jsou součástí deploy konfigurace. Pokud chybí `VITE_SUPABASE_*`, aplikace se **záměrně** nespustí a zobrazí jasnou chybu (fail-fast v `main.tsx`).

3.4 Mobilní aplikace

Podrobně v `app/BUILD.md`. Člověkem dodávané části:

- **Firebase config**: `google-services.json` (Android) + `GoogleService-Info.plist` (iOS) + plugin `com.google.gms.google-services`. Bez nich appka *funguje*, jen bez push notifikací (start je odolný).
- **Podpisový klíč**: vytvořit keystore a vyplnit `android/key.properties` (mimo git). Bez něj se release podepíše debug klíčem (jen pro vývoj).
- **Ikona**: nahradit placeholder `assets/icons/app_icon.png` a spustit `dart run flutter_launcher_icons`.
- **Konfigurace**: vyplnit `dart_defines/prod.json` (prod Supabase URL/klíč).

Build:

```
flutter pub get
dart run build_runner build --delete-conflicting-outputs
flutter build appbundle --release --dart-define-from-file=dart_defines/prod.json
flutter build ipa       --release --dart-define-from-file=dart_defines/prod.json
```

Deep linky (doménové soubory). Pro ověřené `https` odkazy hostujte na doméně `/.well-known/assetlinks.json` (Android) a `apple-app-site-association` (iOS). Schéma `placesecrets://` funguje i bez nich (callbacky platby).

4 Webové administrační rozhraní

Administrace je v portálu pod `/admin/*` (přihlášení e-mailem + PIN). Viditelnost položek řídí role přihlášeného administrátora (ACL).

Sekce	Co se zde spravuje
`/admin/dashboard`	Přehled, statistiky systému.
`/admin/cities`	Města (název, země, poloha, ceny, aktivace).
`/admin/cities/.../pois`	Místa (POI) ve městě: obsah, foto, audio, úroveň přístupu, ceny, slug.
`/admin/cities/.../pricing`	Cenotvorba města (bundle).
`/admin/poi-types`	Typy míst (12 typů) + lokalizace názvů.
`/admin/users`	Uživatelé: profil, stav (aktivní/deaktivovaný), GDPR export, granty přístupu.
`/admin/payments`	Platby a účtenky, detail platby, refundace (Stripe).
`/admin/purchases/premium`	Přehled prémiových nákupů.

Sekce	Co se zde spravuje
`/admin/contributors`	Přispěvatelé (autoři obsahu) a jejich profily.
`/admin/hall-of-fame`	Žebříčky přispěvatelů (celkově / dle města / dle místa).
`/admin/moderation`	Moderace recenzí (skrýt/smazat nevhodné komentáře).
`/admin/landing`	CMS úvodní stránky: hero, Explore, Featured, How-it--works, CTA, patička – per 11 jazyků.
`/admin/settings`	Systémová nastavení, platební konfigurace.
`/admin/acl`	Matice oprávnění: role × zdroj × čtení/zápis/mazání.
`/admin/my-pois`	Přispěvatel spravuje jen vlastní místa.
`/admin/profile`	Profil administrátora/přispěvatele, změna PIN.

Role. `superadmin` (vše), `editor` (POI + audio), `viewer` (jen čtení), `contributor` (vlastní POI + profil), `user` (čtení obsahu). Konkrétní práva jsou v tabulce `acl_permissions` a editovatelná na `/admin/acl`.

5 Zabezpečení

Bezpečnostní model stojí na principu *„frontend nikdy nedrží silný klíč“* a *„databáze chrání sama sebe (RLS)“*.

5.1 Autentizace a autorizace

- **Koncoví uživatelé**: anonymní session (okamžité použití) → e-mail/heslo nebo OAuth (Google/Apple). Anonymní data se migrují při registraci.
- **Administrátoři**: e-mail + **PIN**. PIN je hashovaný (bcrypt), po 5 chybách 15min zámek (`verify-admin-pin`, atomické počítání pokusů). První přihlášení vynutí změnu PINu (`must_change_pin`).
- **ACL**: každá admin operace ověří právo (role × zdroj × R/W/D) v `acl_permissions`; `superadmin` má bypass.

5.2 admin-api proxy – žádný service_role ve frontendu

Frontend **nikdy** nepoužívá `service_role` klíč. Všechny privilegované operace jdou přes edge funkci `admin-api`, která: ověří JWT a roli, validuje názvy sloupců, blokuje citlivé sloupce (`pin_hash` apod.), povoluje jen whitelist tabulek a RPC, vynucuje ACL a loguje do `audit_logs`.

5.3 Row Level Security (RLS)

Zapnuté na všech tabulkách. Uživatel vidí/edituje jen vlastní řádky (`auth.uid()`); veřejná data (aktivní města/místa, `landing_config`) mají `public read`; zápis přes `service_role` (edge funkce) RLS obchází řízeně.

5.4 Storage (úložiště)

Buckety: `poi-photos`, `audio-guides` (veřejné čtení), `avatars` (veřejné čtení, zápis jen vlastník), `payment-receipts` (privátní – servíruje se přes krátkodobé *signed URL*; navíc owner-read RLS policy jako defense-in-depth), `premium-audio` (jen pro nakupující).

5.5 Platby a webhooky

- **Stripe**: webhook ověřuje podpis (`constructEvent`); granty idempotentní.

- **Comgate**: webhook po kontrole sdíleného secretu *re-ověřuje* transakci voláním Comgate status API (merchant+secret+transId) a grantuje jen na ověřené `PAID`; refId/cena se berou z ověřené odpovědi, ne z těla callbacku.
- **Refundace**: jen administrátor s ACL na `payments`; idempotentní (Stripe idempotencyKey).

5.6 Hodnocení míst

Hodnotit smí jen **přihlášený** (neanonymní) uživatel, **jednou na položku** (UNIQUE `poi_id,user_id` + upsert). Anonymní zápis je odebrán na úrovni DB (migrace 0453) i aplikace.

5.7 GDPR

- **Export dat**: uživatel si stáhne svá data (web i mobil).
- **Smazání účtu**: `delete-user-data` atomicky smaže data + storage + auth usera a zapíše doklad do `audit_logs` (`gdpr_account_deletion`).
- **Souhlasy**: časová razítka přijetí Podmínek/Soukromí při registraci; cookie lišta na webu (jen nezbytné úložiště, bez trackingu).

5.8 Web – bezpečnostní hlavičky

Deploy konfigurace nastavuje `Content-Security-Policy`, `X-Frame-Options`, `X-Content-Type-Options`, `Referrer-Policy` a `Permissions-Policy`.

5.9 Správa tajných klíčů

Kde	Co
Supabase secrets	`STRIPE_SECRET_KEY`, `STRIPE_POI_WEBHOOK_SECRET`, `COMGATE_MERCHANT/SECRET`, `WEBHOOK_SECRET`, `RESEND_API_KEY` – jen na serveru.
Web (build env)	`VITE_SUPABASE_URL`, `VITE_SUPABASE_ANON_KEY` (publikovatelný), `VITE_SENTRY_DSN`.
Mobil (dart-define)	`SUPABASE_URL`, `SUPABASE_ANON_KEY` v `dart_defines/prod.json`.
Mobil (keystore)	`android/key.properties` – mimo git.

Nikdy necommitovat reálné klíče; v repu jsou jen `*.example` šablony.

6 Údržba a provoz

6.1 CI/CD

GitHub Actions (`.github/workflows/ci.yml`) na každý push/PR spouští:

- **web**: lint, `tsc`, build, `vitest` (293 testů), `npm audit`.
- **edge-functions**: `vitest` (72 testů).
- **mobile**: `flutter analyze` + `flutter test` (233 testů) + codegen.
- **e2e**: Playwright (5 testů veřejných toků v prohlížeči).

6.2 Monitoring

Web: Sentry (volitelné, aktivní jen když je nastaveno `VITE_SENTRY_DSN`). Mobil: doporučeno Firebase Crashlytics (vyžaduje Firebase config). Edge chyby jsou v logu Supabase.

6.3 Migrace databáze

Konvence: **forward-only**, nepřečíslovávat. Nová změna = nový soubor `NNNN_popis.sql` (idempotentní – `IF NOT EXISTS` apod.). Aplikace: `npx supabase db push`. Lokálně po editaci: `npx supabase db reset`.

6.4 Zálohy a obnova

Spoléhat na Supabase *Point-in-Time Recovery* (dle plánu projektu). Před velkými zásahy ruční záloha (export). Doporučen oddělený **staging** projekt pro testy nasazení.

6.5 Časté administrátorské úkoly

- **Přidat město / místo**: `/admin/cities` → POI editor (foto, audio, ceny, slug).
- **Udělit přístup uživateli**: `/admin/users/:id` (grant město/POI/země).
- **Moderace**: `/admin/moderation` (skrýt/smazat komentář).
- **Změnit ceny / free limit**: `/admin/settings` (`payment_config`).
- **Upravit úvodní stránku**: `/admin/landing` (per jazyk).
- **Přidat administrátora**: pozvánka (`invite-contributor`) / `/admin/users`.

7 Řešení problémů

Příznak	Příčina / řešení
Web ukazuje „Configuration error“	Chybí `VITE_SUPABASE_*` v build env hostingu.
Přímý odkaz na `/admin/...` vrací 404	Chybí SPA fallback – ověřit `netlify.toml`/`vercel.json`.
Platba projde, ale přístup se neobjeví	Webhook nedoběhl/nedorazil; ověřit endpoint a secrety brány; stránka úspěchu sama poolluje nárok.
Mobil spadne hned po startu	Chybí Firebase config; ověřit `google-services.json`/plist (start je jinak odolný).
Push notifikace nedorazí	Není FCM token na serveru / chybí Firebase config / oprávnění notifikací.
Edge funkce vrací 503	Chybí příslušný secret (např. Comgate/Stripe) – `supabase secrets set`.
Admin se nepřihlásí (zámek)	15min zámek po 5 chybných PINech; počkat nebo reset přes superadmina.

8 Odkazy

- `app/BUILD.md` – build mobilu, Firebase, keystore, deep linky, OAuth.
- `backend/DEPLOYMENT.md` – nasazení backendu (migrace, secrets, funkce).
- `backend/PRODUCTION_SETUP.md` – produkční data (countries, admin, ceny).
- `RELEASE-CHECKLIST.md` – co musí udělat člověk vs. co je hotové v kódu.
- `APP-GAP-ANALYSIS.md` – stav, analýza, ověření.

Tento dokument popisuje stav systému k datu na titulní straně. Runtime chování závislé na účtech a zařízeních (platby, push, deep linky, store buildy) je nutné ověřit v cílovém prostředí.